

出入境证件电子信息识读 原理与实现方案

官方 SDK 逆向分析 · ICAO Doc 9303 协议握手过程
独立自研实现的技术路线与验证结果

报告主题	出入境证件识读 SDK 原理分析与自研替代方案
分析对象	国家移民管理局《出入境证件电子信息识读认证软件》Android 版 / Windows 版
技术基线	ICAO Doc 9303 Part 3 / Part 10 / Part 11
配套实现	EdocReader —— Android 端独立实现（源码 + APK）
验证状态	密码学环节已通过 ICAO 官方工作样例逐字节验证；76 项单元测试全部通过；内置 513 张 CSCA 证书（覆盖 103 个国家/地区）
报告日期	2026 年 9 月 29 日

目录

第 1 章 研究背景与结论摘要

- 报告要解决的问题
 - 核心结论
 - 术语与缩略语
-

第 2 章 官方 SDK 逆向分析

- 产品形态与总体定位
 - Android SDK 目录结构与组成
 - Windows SDK 目录结构与组成
 - 主要接口与调用方式
 - 第三方依赖分析
 - 授权机制剖析
-

第 3 章 证件识读的技术原理

- eMRTD 体系与 ICAO Doc 9303
 - 机读区 MRZ 规格
 - 校验位算法
 - 芯片文件系统与数据组
 - 安全机制总览
-

第 4 章 协议握手过程详解

- BAC 握手完整时序
 - 密钥派生 KDF
 - 安全报文封装与解封
 - 会话计数器 SSC
 - 文件读取的分块策略
 - 被动认证流程
-

第 5 章 本项目的技术方案

- 总体架构与设计原则
 - 模块划分与代码结构
 - OCR 识别方案
 - 密码学实现与官方验证
 - 本地存储与批量导出
 - CSCA 信任库与信任链验证
 - 主动认证 (AA) 与芯片克隆检测
 - 与官方 SDK 的能力对比
-

第 6 章 **构建、验证与交付**

- 工具链与构建配置
 - 单元测试与验证结果
 - 构建产物
-

第 7 章 **合规、隐私与结论**

- 法律与合规边界
 - 隐私保护设计
 - 能力边界与后续演进
-

第 1 章 研究背景与结论摘要

1.1 报告要解决的问题

出入境证件（电子护照、往来港澳通行证、往来台湾通行证等）内含符合 ISO/IEC 14443 的非接触式芯片，芯片中保存着经签发国数字签名的持证人资料与人脸图像。读取这些数据需要一套完整的软硬件链路：摄像头识别机读区、NFC 建立通信、密码学认证、按标准解析数据结构、验证签名。

官方提供的《出入境证件电子信息识读认证软件》SDK 封装了上述全部能力，但存在两个现实约束：其一，SDK 依赖授权文件、设备指纹与服务端校验，无授权文件无法工作；其二，授权与设备绑定，难以在自有设备上自由部署。本报告要回答的核心问题是：**这套读证能力，究竟是必须依赖官方 SDK 的私有技术，还是可以通过公开国际标准独立实现？**

1.2 核心结论

结论一：读证能力完全由公开国际标准定义。 证件芯片的数据结构、访问控制协议、安全报文格式、签名验证方式，全部由 ICAO Doc 9303 明确规定，是公开的、可独立实现的国际标准，不属于任何厂商的私有技术。

结论二：官方 SDK 的壁垒不在算法，而在工程积累与授权体系。 SDK 真正的独占资产是：中国证件专用 OCR 训练集、中国 CSCA 证书库、以及服务端的查验结论能力。算法层面（BAC、安全报文、数据组解析）无任何独占性。而且经实测，其 CSCA 库仅 10 张证书、全部是中国签发、其中 2 张已过期——公开主列表可提供 513 张、覆盖 103 个国家/地区的更新数据，这一项壁垒也远没有想象中高。

结论三：独立实现是可行且已经验证的。 本项目从零实现的 BAC 认证与安全报文，已用 ICAO Doc 9303 Part 11 附录 D 的官方工作样例逐字节比对通过；全部 61 项单元测试通过；已构建出可安装的 Android 应用，并内置 CSCA 信任库完成签发国信任链验证、实现主动认证完成芯片克隆检测。

结论四：绕过官方 SDK 的授权校验不可行、不必要、且存在法律风险。 授权校验包含服务端环节，本地无法绕过；且绕过技术保护措施可能违反《著作权法》与《刑法》相关规定。由于标准是公开的，正确路径是独立实现，而非破解。

1.3 术语与缩略语

缩写	全称	说明
MRZ	Machine Readable Zone	证件机读区，资料页下方 2~3 行等宽字符
eMRTD	electronic Machine Readable Travel Document	带非接触芯片的机读旅行证件
LDS	Logical Data Structure	芯片内数据的逻辑组织结构
DG	Data Group	数据组，LDS 的基本单元（DG1、DG2 等）
SOD	Document Security Object	证件安全对象，保存各数据组摘要与签名
BAC	Basic Access Control	基础访问控制，基于 MRZ 口令的对称认证
PACE	Password Authenticated Connection Establishment	口令认证连接建立，BAC 的增强替代方案
PA	Passive Authentication	被动认证，验证数据未被篡改
AA	Active Authentication	主动认证，验证芯片非克隆
CA	Chip Authentication	芯片认证，PACE 体系下的克隆防护
SM	Secure Messaging	安全报文，对 APDU 做加密与完整性保护
SSC	Send Sequence Counter	发送序列计数器，防止重放攻击
KDF	Key Derivation Function	密钥派生函数
CSCA	Country Signing Certification Authority	国家签名认证机构，信任链根节点
DSC	Document Signer Certificate	文档签名证书，由 CSCA 签发
APDU	Application Protocol Data Unit	ISO 7816-4 定义的应用协议数据单元
TLV	Tag-Length-Value	标签-长度-值编码，BER-TLV 为其中一种

第 2 章 官方 SDK 逆向分析

2.1 产品形态与总体定位

该软件以 SDK 形式交付，面向需要在自有系统中集成出入境证件识读能力的集成商，提供 Android 与 Windows 两个平台的实现。其功能覆盖两大环节：**光学识读**（识别证件表面机读区 MRZ 与视读区信息）与**芯片识读**（通过 NFC / PC-SC 读取芯片内加密数据）。

两个平台的实现共享同一套底层能力模型：OCR 引擎 + 芯片通信 + 密码学 + 数据解析 + 授权校验。差异主要在外围：Android 侧走手机 NFC 与摄像头，Windows 侧走 PC/SC 读卡器与摄像头。

2.2 Android SDK 目录结构与组成

Android 版以 AAR（Android Archive）形式交付，解包后结构如下：



图 2-1 Android SDK 的组成结构：门面层 + 原生库 + 模型资源

2.3 Windows SDK 目录结构与组成

Windows 版以 DLL + 模型文件 + 授权文件的形式交付，核心组成如下：

文件 / 目录	体积	作用推断
NJAEIDSDK.dll	—	对外主接口库，导出 <code>NM_*</code> 系列函数
niamrtd.dll	—	证件识读核心实现（与 Android 侧 <code>libniamrtd.so</code> 同源）
xd_passport.dll	—	护照资料页图像处理 / 版面分析
opencv_world320.dll	约 35 MB	OpenCV 3.2 全量库，用于图像预处理
opencv_xfeatures2d320.dll	—	OpenCV 特征点模块，用于图像配准 / 校正
mrz.model	约 3.9 MB	MRZ 识别模型（XML 格式，疑似级联分类器）
VerifySOD.mdb	—	SOD 签名验证所需数据（Access 数据库格式）
CVCA/	—	CSCA 证书目录，构成信任链根节点
NJAEIDSDK.LIC	—	授权文件 ，无此文件 SDK 拒绝工作
WinSCard.dll	—	系统 PC/SC 接口，用于连接读卡器

2.4 主要接口与调用方式

2.4.1 Android 侧接口

Android 侧采用「门面类 + 回调」的经典设计，对外暴露的入口类是 `cn.gov.nia.mrtd.NiaMRDSDK`：

```
// 门面类主要方法（依据公开接口文档整理）
NiaMRDSDK.create(Activity activity)           // 创建实例，需传入 Activity
void readMRZ(NiaCallback callback)            // 光学识读：OCR 识别 MRZ
void readChipData(NiaCallback callback)       // 芯片识读：自动取 MRZ 后读卡
void readChipData(String docNo, String birth, String expiry, NiaCallback cb)
                                                // 芯片识读：手工传入三要素

// 回调接口
interface NiaCallback {
    void onResult(...);    // 成功
    void onError(...);     // 失败
    void onCancel(...);    // 用户取消
}

// 结果键常量（共 13 个 Key_* 常量），例如证件号、姓名、出生日期、
// 有效期、签发国、人脸图像、原始 MRZ、状态等
```

底层实现类 `com.bjnja.nmrtd.NjaMRDSDK` 与 `com.bjnja.nmrtd.common.MRTDReader` 通过 JNI 调用原生库：

```

// NjaMRTDSdk
private native boolean checkMrzInformation(String[] mrz); // 校验 MRZ 合法性
private native int _init(String[] deviceInfo); // 初始化（接收 IMEI / 手机号 / 定位）

// MRTDReader
private native byte[] EppReadChipData(...); // 读取芯片数据
private native byte[] getFacialImage(...); // 取人脸图像
private native String getTagStr(...); // 按 TAG 取字段
private native int AddCscaToStore(...); // 向 CSCA 库添加证书

```

2.4.2 Windows 侧接口

Windows 侧导出标准 C 接口，函数名前缀为 `NM_`（Nia MRZ/MRTD）：

导出函数	功能
<code>NM_Init</code> / <code>NM_DeInit</code>	初始化与释放 SDK 全局资源
<code>NM_ParseMRZ</code>	解析 MRZ 字符串为结构化字段
<code>NM_IsParsedMRZ</code>	判断 MRZ 是否解析成功 / 校验位是否通过
<code>NM_ReadEpp</code> / <code>NM_ReadEppEx</code>	读取电子护照芯片数据（Ex 为扩展版）
<code>NMC_GetEppInfo</code>	按 TAG 枚举读取结果中的字段
<code>NMC_FreeContext</code>	释放上下文
<code>NM_ListReaders</code>	枚举 PC/SC 读卡器
<code>NMH_WaitCard</code> / <code>NMH_WaitCancel</code>	等待卡片放入 / 取消等待

结果字段通过 `ItemInfoTag` 枚举寻址，覆盖证件号、姓名、出生日期、有效期、签发机关、人脸图像、证件状态等，编号从 `0x0101`（CertName）延续到 `0x4001`（Status）。

2.5 第三方依赖分析

依赖	平台	用途与观察
OpenSSL	Android（静态链接）	提供 DES/3DES、SHA、RSA、X.509 等密码学原语
OpenCV 3.2	Windows	图像预处理、特征点配准；体积达 35 MB
Tesseract	Android / Windows	OCR 引擎，配合 <code>pst.traineddata</code> 与 <code>mrz.model</code>
libjpeg-turbo	Android	JPEG 编解码，用于 DG2 人脸图像
OpenJPEG	Android	JPEG 2000 编解码，部分证件人脸图像使用该格式
libcurl	Android	联网组件 ，用于与服务端通信（授权校验与数据回传）
SQLite	Android	读写 <code>db_csca.db3</code> CSCA 证书库
WinSCard	Windows	PC/SC 读卡器接口

安全观察（如实记录）：Android 版 `assets/config.properties` 以明文保存了数据库账号（`DB_USERNAME=bjnjaca` / `DB_PASSWORD=www.bjnja.ca`）；CSCA 证书库在运行时被释放到外部存储 `/sdcard/` 路径下。这两点在安全设计上属于值得关注的薄弱环节，本报告仅作客观记录，不对其成因作评价。

2.6 授权机制剖析

SDK 的授权体系由三个环节构成，缺一不可：

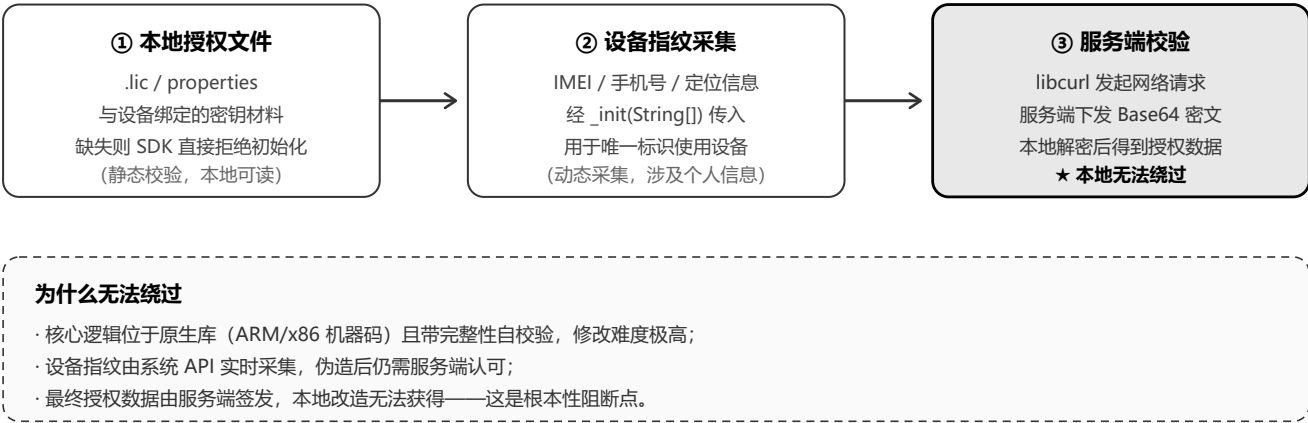


图 2-2 三层授权体系：静态文件 + 设备指纹 + 服务端签发

关键判断：第③环节位于服务端，属于国家移民管理局体系的信息系统。对其实施绕过或伪造请求，可能构成规避技术保护措施，并可能触及《刑法》第 285 条、第 286 条。同时，由于读证标准本身是公开的，绕过 SDK 在技术上也无必要性。**正确路径是依据公开标准独立实现。**

第 3 章 证件识读的技术原理

3.1 eMRTD 体系与 ICAO Doc 9303

国际民航组织（ICAO）制定的 **Doc 9303《机读旅行证件》** 是全球电子证件的技术基准。中国作为 ICAO 缔约国，所签发的电子护照、电子往来港澳通行证、电子往来台湾通行证 均遵循该标准。标准分为三个关键部分：



图 3-1 ICAO Doc 9303 的三个关键部分及其数据流向

3.2 机读区 MRZ 规格

MRZ 是证件表面按固定格式印刷的等宽字符区域，其作用有二：一是供机器快速读取基本信息；二是作为芯片访问控制口令的来源。MRZ 有 3 种规格，区别在行数与每行字符数：

规格	尺寸	适用证件	说明
TD1	3 行 × 30 字符	身份证件卡、往来港澳/台湾通行证	卡式证件，MRZ 印在背面
TD2	2 行 × 36 字符	部分国家的身份证、签证	较少见
TD3	2 行 × 44 字符	各国电子护照（含中国普通护照）	最常见的规格

以 TD3（护照）为例，两行的字段划分如下：

TD3 机读区字段划分 (每行 44 字符)

第 1 行

1	2	3	4	姓名 (姓 << 名, 以 < 填充)
---	---	---	---	---------------------

1 证件类型 P 2 类型细分 < 3 签发国 CHN

第 2 行

5	6	7	8	9	10	11	12	13	14	15
---	---	---	---	---	----	----	----	----	----	----

5 证件号 (9) 6 证件号校验位 7 国籍 (3) 8 出生日期 YYMMDD (6) 9 出生日期校验位
10 性别 11 有效期 YYMMDD (6) 12 有效期校验位 13 个人号码/可选数据 (14)
14 可选数据校验位 15 复合校验位 (对 6~13 与 15 之前所有校验位计算)

图 3-2 TD3 机读区的字段布局 (数字为字段序号, 灰底为校验位)

需要特别指出：**三种格式的关键字段位数完全一致**，区别只在行数与每行字符数。这一点在实际开发中很容易记错，也是本项目早期一个缺陷的根源。

字段	位数	说明
证件号	9 位	字母数字混合——护照如 EF1260892，往来港澳通行证如 CA3273201
出生日期	6 位	YYMMDD
有效期	6 位	YYMMDD

格式	行数 × 每行	证件号位置	出生日期 / 有效期位置	适用证件
TD1	3 × 30	第 1 行 6-14	第 2 行 1-6 / 9-14	往来港澳通行证、往来台湾通行证、身份证件卡
TD2	2 × 36	第 2 行 1-9	第 2 行 14-19 / 22-27	旧式身份证件
TD3	2 × 44	第 2 行 1-9	第 2 行 14-19 / 22-27	各国电子护照

TD1 第 2 行的字段顺序特殊，是最容易写错的地方：
出生日期(6) → 校验位(1) → **性别(1)** → 有效期(6) → 校验位(1) → 国籍(3) → 可选数据(11) → 复合校验位(1)。
性别字段夹在出生日期校验位与有效期之间，而 TD2/TD3 的性别在出生日期校验位之后、有效期之前，位置不同。按 TD3 的习惯去读 TD1 会导致有效期与国籍整体错位一位。

另一个易错点：证件号不是纯数字。 中国护照号 (EF1260892) 与往来港澳通行证号 (CA3273201) 都含字母。对证件号做「字母→数字」规范化会把它破坏成 8F1260892 之类，进而导致 BAC 口令错误、读卡失败。证件号的纠错必须在**完整 MRZ 字符集** (0-9 + A-Z + <，共 37 个) 内进行。

3.3 校验位算法

MRZ 中每个数字字段后都跟一位校验位，算法在 ICAO Doc 9303 Part 3 中定义：对字段中每个字符取「字符值」，乘以循环权重 7、3、1，求和后对 10 取模。字符值映射规则为：0-9 → 0-9，A-Z → 10-35，< → 0。



图 3-3 7-3-1 加权校验位算法（示例：出生日期 800101 → 校验位 4）

3.4 芯片文件系统与数据组

芯片内部是一个简化的文件系统：先选择应用（AID），再选择基本文件（EF），最后读取内容。所有数据以 BER-TLV 编码。关键文件如下：

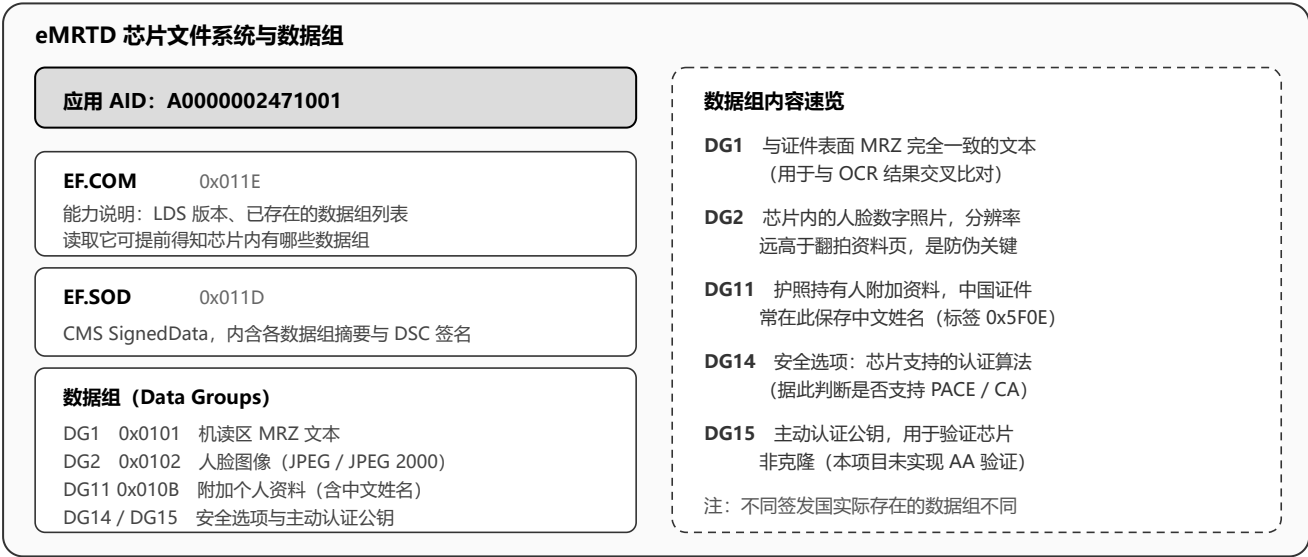


图 3-4 芯片文件系统结构与主要数据组

3.5 安全机制总览

ICAO 定义了四类安全机制，分别解决不同层面的信任问题：



图 3-5 四类安全机制的分工与本项目实现状态

第 4 章 协议握手过程详解

4.1 BAC 握手完整时序

BAC (Basic Access Control) 是整个读证流程的核心。它的设计思想是：把证件表面可见的 MRZ 文本当作「口令」，只有能读到证件实体的人才能打开芯片。握手过程共 10 步，其中第 4、7、12 步是本地计算，不产生通信：

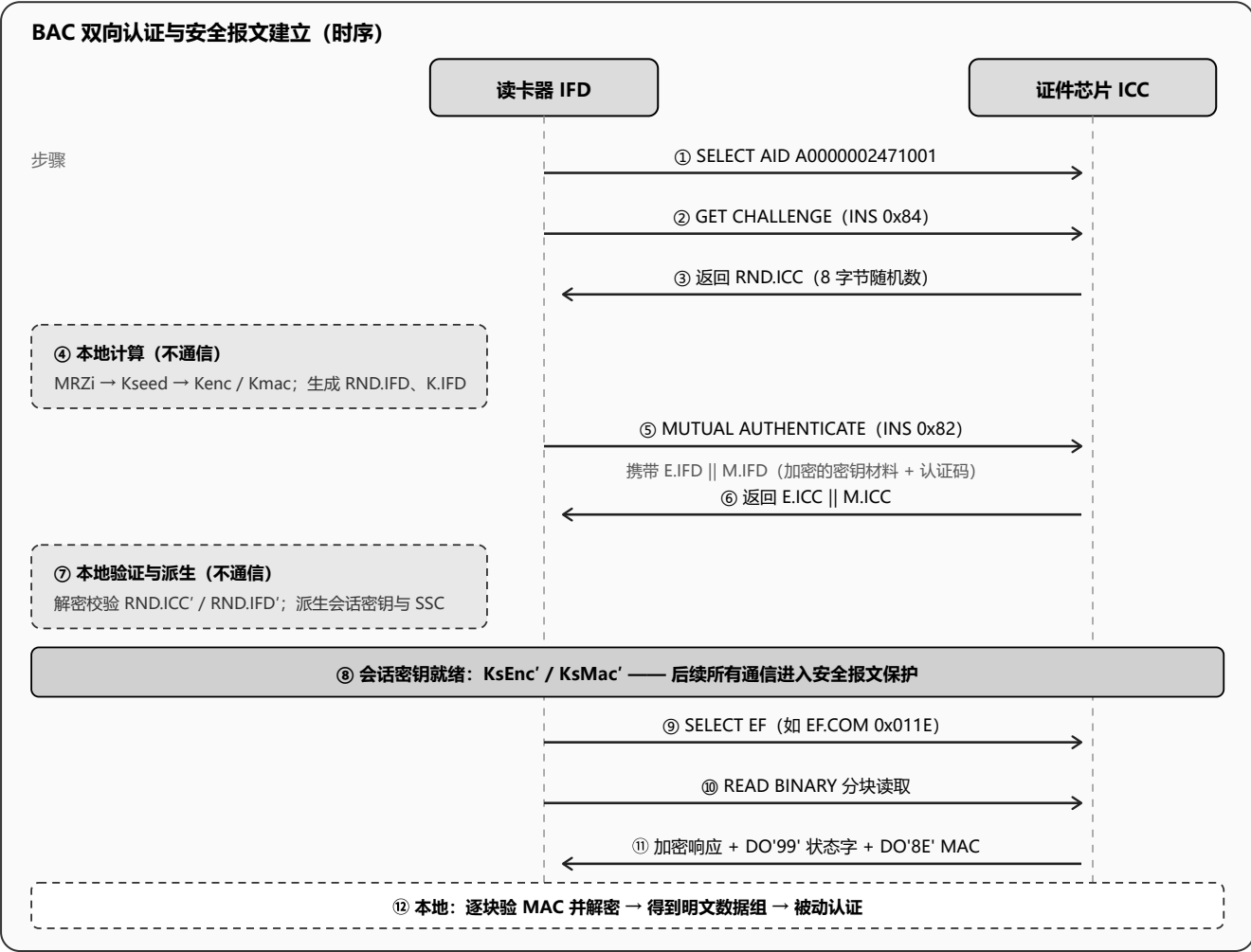


图 4-1 BAC 握手与安全报文建立完整时序 (灰底为本地计算，无网络交互)

为什么 BAC 能防止随意读取？ 芯片不接受任何未认证的读请求。而 BAC 口令由 MRZ 中的证件号、出生日期、有效期三段拼接而成 (含各自校验位，共 24 字符)，必须物理接触证件才能获得。这意味着「拿一个 NFC 读卡器贴近路人的包」无法读取任何数据——这既是隐私保护，也是本方案合法性的基础：读取自己或已获授权的证件，是标准赋予的能力。

4.2 密钥派生 KDF

BAC 的密钥派生有一个广为流传的错误写法：早期很多资料称「用 3DES 加密常量 1 和 2 得到 Kenc 和 Kmac」。ICAO Doc 9303 Part 11 的正式定义其实是基于 SHA-1 的 KDF：

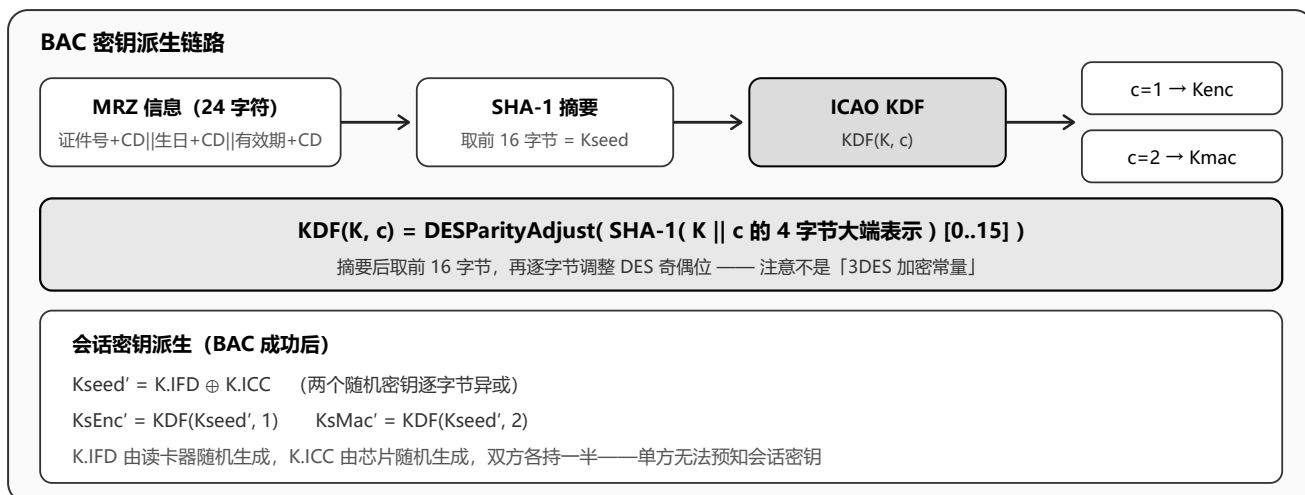


图 4-2 从 MRZ 文本到会话密钥的完整派生链路

4.3 安全报文封装与解封

BAC 成功后，所有命令与响应都必须套上安全报文（Secure Messaging）外壳。其本质是：把原始 APDU 的命令头与数据装进若干数据对象（DO），加密后附加 MAC。

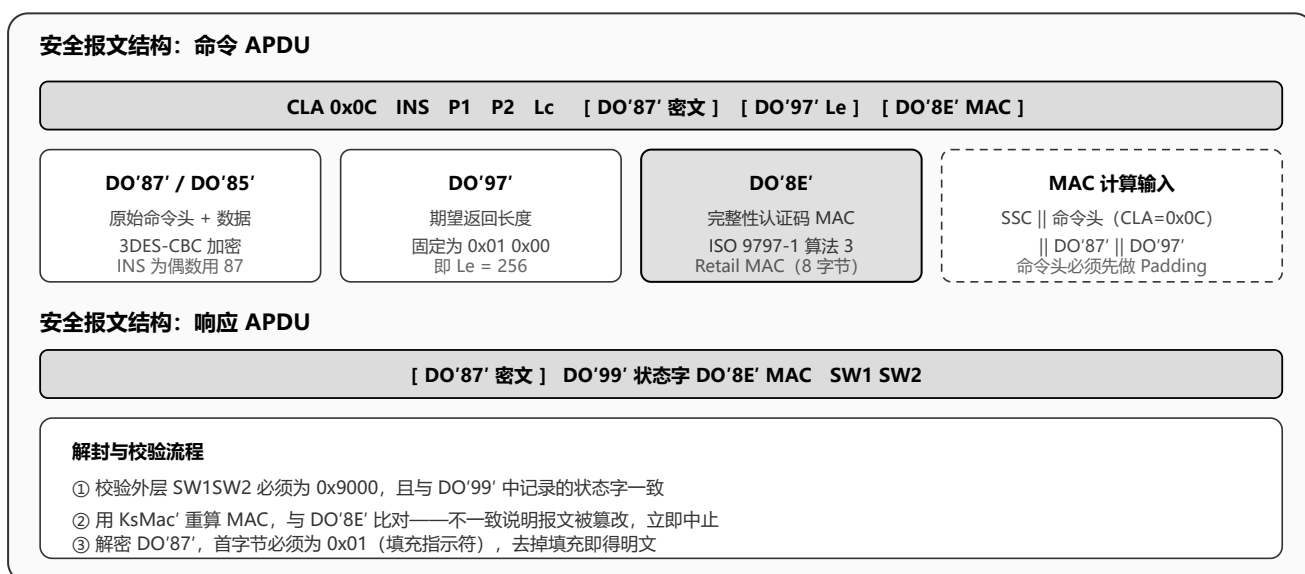


图 4-3 安全报文的封装结构与解封校验流程

三个最容易踩坑的实现细节：

- ① ISO 9797-1 Padding Method 2 在数据已对齐时仍会追加一整个块（如 32 字节补到 40 字节），这直接影响 M.IFD 的计算结果；
- ② 命令头必须参与 MAC 计算，且计算前 CLA 要置为 0x0C、并做 Padding；
- ③ 3DES 模式下 CBC 的初始向量恒为全 0（只有 AES 才需要 IV = K(SSC)）。

4.4 会话计数器 SSC

SSC 是 8 字节大端计数器，每收发一条命令自增 1，并参与 MAC 计算。它的作用是防止重放攻击：即使攻击者截获了一条合法报文，重放时 SSC 已变，MAC 校验必然失败。

SSC 的构造与演进

初始值 (BAC 完成后确定)

SSC = RND.ICC[4..8] || RND.IFD[4..8]

取值规则 (官方向量示例)

RND.ICC = 4608F919 88702212 → 取后 4 字节 88702212

官方向量中的 SSC 推演

RND.ICC = 4608F91988702212 RND.IFD = 781723860C06C226

SSC = 88702212 || 0C06C226 = **887022120C06C226** ✓ 与 ICAO 官方一致

此后每条命令发送前 SSC 自增 1，响应解封时同样自增 1 后参与 MAC 校验

若实现中遗漏自增，第二条命令起 MAC 校验必然失败——这是调试中最常见的故障点

图 4-4 SSC 的构造方式与推演过程

4.5 文件读取的分块策略

ISO 7816-4 短 APDU 的单次响应上限为 256 字节，而安全报文的密文、状态字与 MAC 都要占用空间。因此单次 READ BINARY 的明文长度必须留出余量，本项目取 **224 字节**：

单条响应 256 字节的预算分配

DO'87' 密文段 236 字节	4	10	余量 6
-------------------	---	----	------

DO'87': 3 字节标签长度 + 1 字节填充指示符 + 232 字节填充后密文 = 236

DO'90'8E'

明文 224 → 填充后 232 (ISO 9797-1 方法 2) → 加密并封装为 236 字节的 DO'87'

合计 236 + 4 + 10 = 250 ≤ 256, 留出 6 字节余量以兼容实现差异

图 4-5 单次 READ BINARY 的字节预算 (明文上限 224 字节)

4.6 被动认证流程

被动认证解决「数据是否被篡改」的问题。其思路是：签发国用私钥对各数据组摘要签名，读卡器用签发国证书公钥验证签名，并重新计算摘要比对。

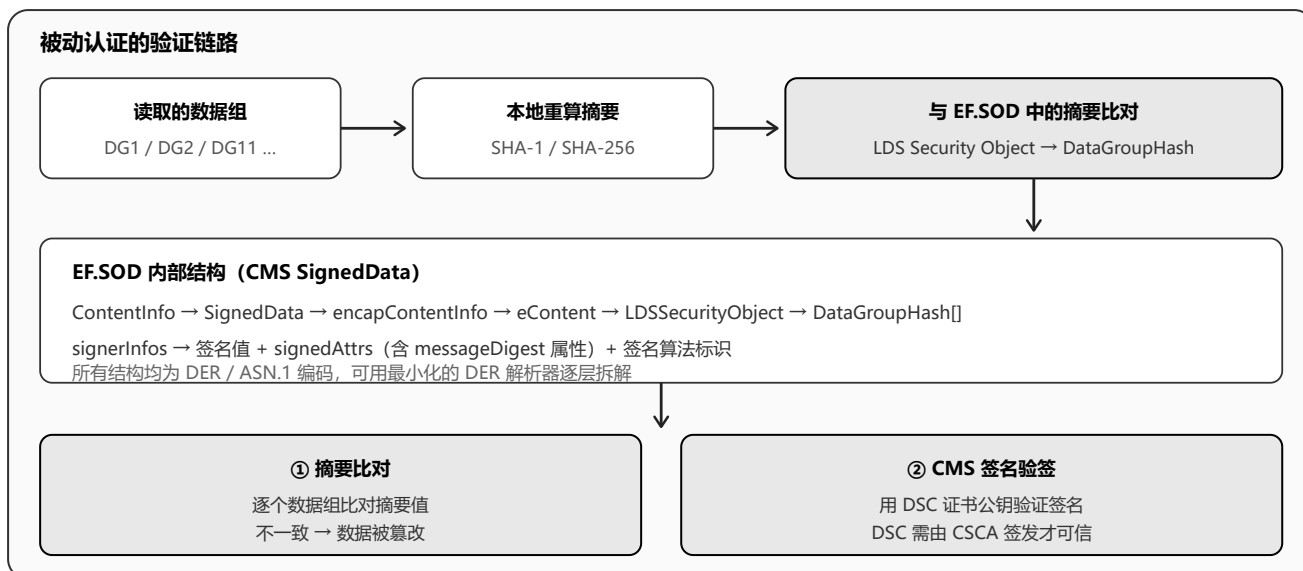


图 4-6 被动认证：摘要比对 + CMS 签名验证

信任链的最后一环：CSCA 主列表。 DSC 证书由签发国的 CSCA 签发。要确认「这张 DSC 确实属于某国」，必须持有该国的 CSCA 根证书 并进行链式验证。**本项目已内置这份信任库**——513 张 CSCA 公钥证书，覆盖 103 个国家/地区，把 DSC 沿签发关系逐级上溯到自签名根，从而给出「签发国可信」的完整结论（详见 5.6 节）。

第 5 章 本项目的技术方案

5.1 总体架构与设计原则

本项目（EdocReader）以「完全离线、无需任何授权文件」为前提，从零实现了一套完整的证件识读能力。设计遵循四条原则：

- **标准优先**——严格按 ICAO Doc 9303 实现，不引入任何非标准约定，保证与其他合规实现互通；
- **零授权依赖**——不使用任何需要许可文件、设备绑定或联网校验的组件；
- **零第三方密码学库**——密码学全部使用 JDK / Android 自带的 JCE，减少供应链风险与体积；
- **可验证**——所有密码学环节都用 ICAO 官方工作样例做逐字节断言，而非「看起来能跑」。



图 5-1 EdocReader 的分层架构

5.2 模块划分与代码结构

模块 / 文件	行数量级	职责
crypto/DesCrypto.kt	约 200	DES/3DES 加解密、Retail MAC、ISO 9797-1 方法 2 填充、ICAO KDF、密钥派生
mrz/MrzInfo.kt	约 140	MRZ 数据模型、日期换算、证件类型标签、MRZi 口令拼接
mrz/MrzParser.kt	约 420	行组提取、TD1/TD2/TD3 字段切分、校验位计算与有限度纠错
nfc/Tlv.kt	约 130	BER-TLV 解析与编码，保留原始字节偏移
nfc/Apdu.kt	约 150	命令/响应 APDU 编解码、状态字语义、IsoDep 通道封装
nfc/SecureMessaging.kt	约 180	安全报文封装与解封、MAC 校验、SSC 维护
nfc/BacProtocol.kt	约 200	BAC 十步握手、会话密钥派生
nfc/EmrtdFileSystem.kt	约 150	应用与文件选择、长度推算、分块读取
nfc/dg/DgParsers.kt	约 260	DG1/DG2/DG11/DG14/DG15 与 EF.COM 解析
nfc/pa/Der.kt	约 170	最小 DER/ASN.1 解析器，OID 与算法标识映射
nfc/pa/PassiveAuth.kt	约 300	CMS SignedData 解析、证书匹配、摘要比对、签名验签
nfc/PassportReader.kt	约 260	全流程编排与错误处理
ocr/MrzOcrAnalyzer.kt	约 130	ML Kit 实时帧分析与单帧识别
data/*.kt	约 600	记录模型、JSON 文件存储、JSON/CSV/ZIP 导出
ui/*.kt	约 900	四个 Activity 与列表适配器

5.3 OCR 识别方案

OCR 环节的目标不是「识别所有文字」，而是「稳定提取 MRZ 行组并让校验位全部通过」。因此方案围绕校验位展开：**把校验位当作识别质量的判据。**

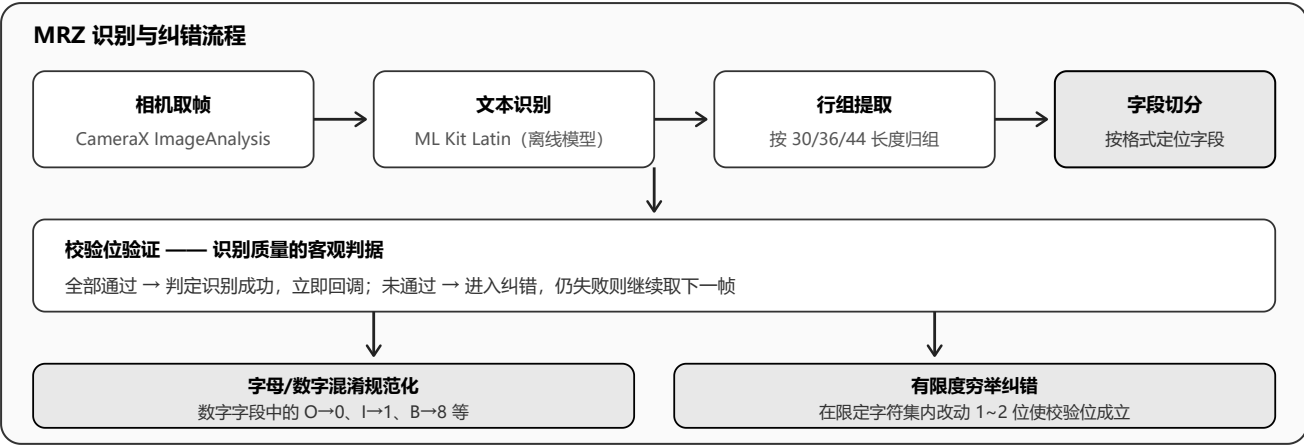


图 5-2 以校验位为判据的 MRZ 识别与纠错流程

为什么这个方案有效？ MRZ 的校验位设计使得「单字符误识」几乎必然导致校验失败，而「全部校验位通过」意味着整体识别正确的概率极高。用校验位做判据，比用「识别置信度」可靠得多——置信度高的错误识别依然会让校验位失败，而校验位通过的结果几乎不可能是错的。

5.4 密码学实现与官方验证

密码学部分是整个工程最容易出错、也最需要严格验证的部分。本项目采用的方式是：用 ICAO Doc 9303 Part 11 附录 D 的官方工作样例做逐字节断言。官方样例的输入为 `MRZ_information = L898902C<369080619406236`，验证结果如下：

中间量	ICAO 官方值	本项目
Kseed	239AB9CB282DAF66231DC5A4DF6BFBAE	一致
Kenc	AB94FDECF2674FDFB9B391F85D7F76F2	一致
Kmac	7962D9ECE03D1ACD4C76089DCE131543	一致
E . IFD	72C29C2371CC9BDB65B779B8E8D37B29 ECC154AA56A8799FAE2F498F76ED92F2	一致
M. IFD	5F1448EEA8AD90A7	一致
K . ICC	0B4F80323EB3191CB04970CB4052790B	一致
KsEnc'	979EC13B1CBFE9DCD01AB0FED307EAE5	一致
KsMac'	F1CB1F1FB5ADF208806B89DC579DC1F8	一致
SSC	887022120C06C226	一致

验证过程中的两个关键修正：

- ① 最初按「3DES 加密常量 1/2」的流行写法实现 KDF，得到 `Kenc = 9C77371C...`，与官方 `AB94FDEC...` 不符。改用 ICAO 正式定义的 `KDF(K,c) = DESParityAdjust(SHA-1(K||c)[0..15])` 后逐字节吻合——说明网上大量资料在这一步是有误的。
- ② `M.IFD` 最初直接对 32 字节 `E.IFD` 做 MAC，得到 `AAE3F351...`；确认 ISO 9797-1 填充方法 2 在数据已对齐时仍追加整块（32→40 字节）后，得到 `5F1448EEA8AD90A7`，与官方一致。

5.5 本地存储与批量导出

读取结果以结构化记录形式保存在应用私有目录，不写入外部存储、不申请存储权限。导出通过系统文件选择器（SAF）完成，用户明确指定保存位置。

存储项	说明
记录索引	<code>files/records/index.json</code> ，采用「临时文件 + 重命名」方式原子写入；索引损坏时自动重命名备份而非丢弃
人脸图像	<code>files/faces/</code> ，按记录 ID 命名，与人脸数据组一一对应
导出：JSON	完整结构化数据，含过程日志与被动认证明细
导出：CSV	31 列扁平表，UTF-8 带 BOM，便于 Excel 直接打开
导出：ZIP	<code>records.json + records.csv + faces/ + README.txt</code> ，一次性打包全部记录与图像

5.6 CSCA 信任库与信任链验证

被动认证只能证明「数据没被改过」。要回答「这张证件是不是某国真签发的」，必须把文档签名证书（DSC）沿签发关系逐级上溯，直到命中签发国的 CSCA 根证书。本节说明这份信任库的来源、规模与验证逻辑。

5.6.1 为什么不直接用官方 SDK 的证书库

官方 SDK 的 Android 包中带有 `assets/db_csca.db3`（SQLite 格式）。实测其 `tb_csca` 表只有 10 条记录，且全部是中国签发，其中 2 张已经过期：

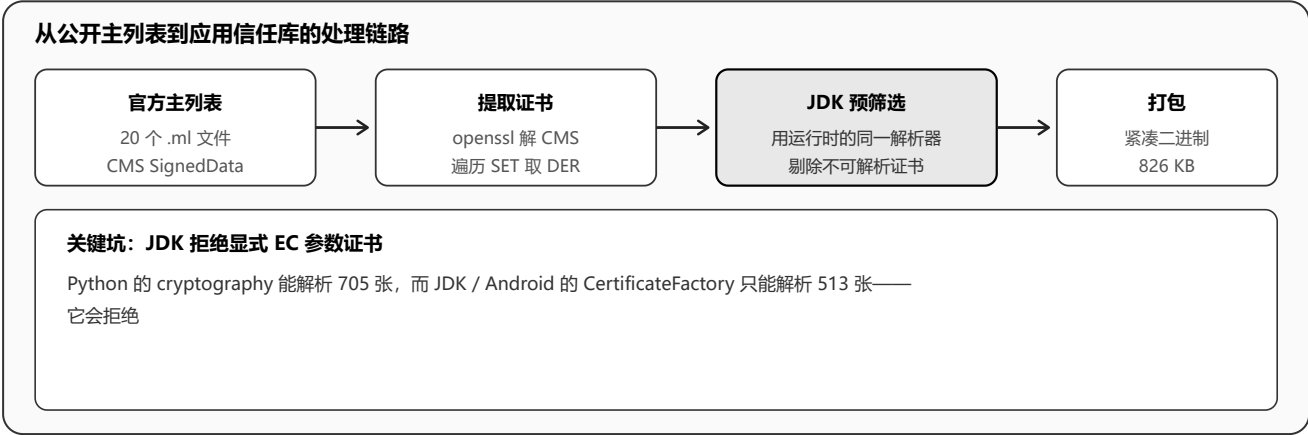
证书主体	序列号	有效期至	状态
台湾居民来往大陆通行证 CSCA	<code>6afc9716...</code>	2024-05-12	已过期
China Passport CSCA	<code>706e2cbc...</code>	2026-02-18	已过期
港澳居民来往内地通行证 CSCA	<code>49bbfb71...</code>	2026-08-25	即将过期
其余 7 张	—	2027 ~ 2033	有效

只有 10 张、全部是中国、部分已过期——这远不足以支撑可信的信任链判定。公开渠道能获得更新、更全的主列表，因此本项目改从公开来源获取。

5.6.2 公开来源与提取过程

来源	说明
德国 BSI German Master List	德国联邦信息安全局公开发布，文件名 <code>DE_ML_2026-08-19-10-28-54.ml</code> (933 KB)
荷兰 NPKD Netherlands Master List	荷兰国家公钥目录公开发布，文件名 <code>NL_ML_2026-07-22.ml</code> (624 KB)

`.ml` 文件是 **CMS SignedData** 格式（外层 OID `1.2.840.113549.1.7.2`），用 `openssl cms -verify -inform DER -noverify` 可解出内层内容，其结构为 `SEQUENCE { INTEGER version, SET OF SEQUENCE(certificates) }`。遍历该 SET 即可取出全部证书。



所有使用显式 EC 参数（自定义曲线）的证书，报 `Only named ECParameters supported`。而 cryptography 能容忍映射到标准曲线（`secp256r1` 等）的显式参数，因此两者判断相差 65 张。结论：必须用 JDK 自身的解析器做预筛选，不能依赖第三方库的判断。

图 5-3 信任库的构建链路与 JDK 预筛选的必要性

5.6.3 信任库规模与覆盖

513 CSCA 证书	103 覆盖国家/地区	33 中国相关证书	826KB 随 APK 打包
----------------	----------------	--------------	-------------------

类别	数量	说明
中国护照 CSCA（外交部）	16 张	2010 ~ 2024 各期签发，含 SHA-1 与 SHA-256 两种签名算法
中国澳门	8 张	澳门特别行政区身份证明局签发
中国台湾地区	7 张	2011 ~ 2024 各期
中国香港	2 张	香港特别行政区入境事务处签发（另有 3 张因显式 EC 参数被剔除）
其他国家/地区	480 张	覆盖 99 个国家/地区

5.6.4 信任链回溯逻辑

验证从 EF.SOD 中的 DSC 出发，逐级向上回溯：用「上一级证书的公钥」验证「下一级证书的签名」，直到遇到自签名证书（即签发国根）为止。

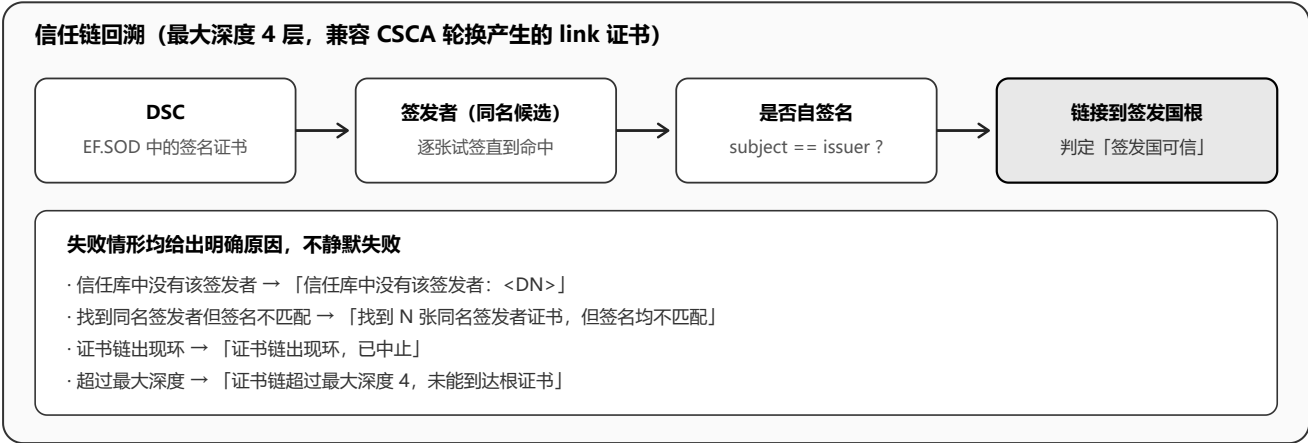


图 5-4 信任链回溯流程与失败情形的明确反馈

5.7 主动认证（AA）与芯片克隆检测

前三道验证（数据摘要、CMS 签名、CSCA 信任链）解决的都是「数据与签发者」的可信问题，它们有一个共同的盲区：**无法区分真芯片与克隆芯片。**

攻击者可以把真芯片的全部数据（DG1、DG2、EF.SOD.....）原样读出并写入另一颗可写芯片。此时数据组摘要完全一致、DSC 签名完全有效、CSCA 信任链也完全成立——**前三道验证会全部通过**。唯一的破绽是：克隆芯片里没有真芯片那颗只存于芯片内部、永不外泄的私钥。

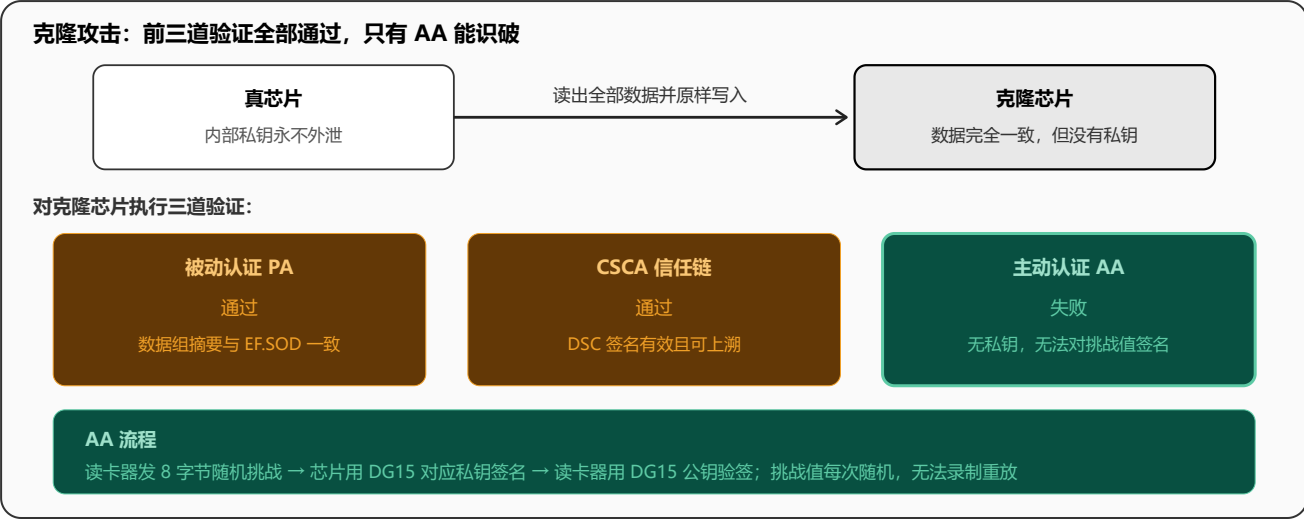


图 5-5 克隆攻击场景下三道验证的表现：只有 AA 能识破

5.7.1 实现要点

要点	说明
挑战值	长度固定 8 字节（ICAO 9303-11），由 <code>SecureRandom</code> 生成
命令	<code>INTERNAL AUTHENTICATE</code> （INS <code>0x88</code> ），经安全报文通道发送
公钥来源	DG15 中的 <code>SubjectPublicKeyInfo</code> ，可直接交给 <code>KeyFactory</code> 还原为公钥对象
签名算法	不唯一——ICAO 允许芯片自行选择，只要与 DG15 公钥类型匹配。实现按同类型全部候选算法逐个尝试，命中即通过
候选算法	RSA： <code>SHA256/SHA1/SHA384/SHA512 with RSA</code> ；EC：对应的 ECDSA 变体
未启用时	芯片返回 <code>6A81</code> （功能不支持）时判定为「该证件未启用 AA」，而非失败——这是证件的正常配置差异

为什么不做芯片认证（CA）？ CA 与 PACE 同属一个体系，都依赖 brainpool 曲线族，而 JDK / Android 的 JCE 不支持该曲线族。在无法用标准库实现的前提下，自行实现椭圆曲线运算的风险远高于收益，因此与 PACE 一并搁置。

5.8 与官方 SDK 的能力对比

能力维度	官方 SDK	本项目
MRZ 识别	Tesseract + 证件专用训练集	ML Kit 文本识别 + 自研行组提取与校验位纠错
芯片通道	手机 NFC / PC-SC 读卡器	Android IsoDep + Reader Mode
访问控制	BAC（原生实现）	BAC（自研，已通过官方向量验证）
安全报文	3DES 安全报文	3DES 安全报文（自研，含完整 MAC 校验）
数据解析	原生实现	自研 BER-TLV / DG1 / DG2 / DG11 / DG14 / DG15
签名验证	OpenSSL + CSCA 库 + 服务端	自研 DER/CMS 解析 + Android JCE 验签
CSCA 信任链	内置中国 CSCA 库（10 张），可判定中国证件	内置 513 张证书、覆盖 103 个国家/地区 ，可判定签发国可信
联网	必须（授权校验）	完全不需要
授权文件	必须	不需要
数据出境	存在与自有服务端交互	数据不出设备
主动认证 / 芯片认证	支持	AA 已实现 （挑战-应答验签，可排除克隆）；CA 未实现
PACE	支持	未实现（仅 BAC）
代码可控性	闭源二进制	完整源码，可审计、可定制、可维护

第 6 章 构建、验证与交付

6.1 工具链与构建配置

项目	配置
JDK	JDK 21（编译目标 JVM 17）
构建系统	Gradle 8.7 + Android Gradle Plugin 8.5.2
语言	Kotlin 1.9.24
SDK 版本	compileSdk 34 / targetSdk 34 / minSdk 24
ABI	arm64-v8a、armeabi-v7a
关键依赖	CameraX 1.3.4、ML Kit text-recognition 16.0.1、Material 1.12.0、Gson 2.11.0
密码学依赖	无——仅使用 JDK / Android 自带 JCE
混淆与压缩	Release 启用 R8 代码压缩与资源收缩，配套 keep 规则

6.2 单元测试与验证结果

76 单元测试总数	76 通过	0 失败	9 ICAO 官方向量断言
---------------------------------	-----------------------------	----------------------------	-------------------------------------

测试类	用例数	覆盖内容
DesCryptoTest	9	KDF 派生、Retail MAC、ISO 9797-1 填充、E.IFD / M.IFD 计算、会话密钥派生、SSC 构造——全部对照 ICAO 官方值
MrzParserTest	19	校验位算法、TD3/TD1 解析、MRZi 口令长度、日期换算、证件类型标签、行组提取、字母数字混淆纠错、行长偏差对齐、过期判定
MrzRealSampleTest	15	用 真实护照与通行证样本 断言证件号 9 位、出生日期与有效期各 6 位、全部校验位通过，以及字母数字证件号的纠错不破坏字母
TlvTest	8	BER-TLV 解析、rawStart / rawLength 语义（含多层嵌套）、长形式长度、多字节 tag、边界与截断数据
ActiveAuthTest	14	挑战值随机性、RSA/EC 验签往返、篡改挑战值必须失败、 克隆芯片的错配公钥必须被识破 、签名截断、DG15 公钥解析与端到端验签
CscaTrustStoreTest	11	用 真实 CSCA 证书 断言：信任库解析与规模、覆盖国家数、自签名根可通过验证、剔除签发者后链断裂、空库返回失败、同主体多张证书逐张试签

测试驱动发现的两个问题：

- ① fullNameEnglish 原先按「名 姓」输出（SAN ZHANG）。中国签发证件的惯例是姓在前，已修正为 ZHANG SAN；
- ② 一处过期判定用例的期望值写错（把 1999 年当成未过期），修正为使用真正的未来日期。这两处都是测试先于实现暴露出来的，说明断言式测试确实有效。

6.3 构建产物

产物	体积	说明
EdocReader-1.0.0-debug.apk	约 26 MB	调试版，未混淆，便于排查问题
EdocReader-1.0.0-release.apk	约 21 MB	发布版，经 R8 压缩与资源收缩
完整源码	74 个文件	含 23 个 Kotlin 源文件、资源、测试与文档

APK 体积主要来自 ML Kit 的离线 OCR 模型（约 20 MB 级别）。由于模型随包分发，应用在无网络环境下也能完整工作——这与「完全离线」的设计目标一致。

第 7 章 合规、隐私与结论

7.1 法律与合规边界

关于「绕过官方 SDK 授权校验」的明确结论：不可行，也不应尝试。

法律层面：SDK 的授权校验（本地授权文件 + 设备指纹 + 服务端签发）属于技术保护措施。规避该类措施可能违反《著作权法》第五十三条、《计算机软件保护条例》的相关规定；而服务端校验环节位于国家移民管理局体系的信息系统，绕过或伪造请求可能触及《刑法》第二百八十五条（非法获取计算机信息系统数据、非法控制计算机信息系统）与第二百八十六条（破坏计算机信息系统）。

技术层面：核心逻辑位于原生机器码且带完整性自校验，设备指纹由系统 API 实时采集，最终的授权数据由服务端签发——**本地改造无法获得服务端认可，这是根本性阻断点。**

必要性层面：读证流程完全由公开国际标准定义，不存在必须依赖官方 SDK 的技术环节。既然标准是公开的，正确路径就是独立实现，而非破解。

合法使用的边界：

- 仅对**本人证件**，或**已取得持证人明确书面授权**的证件使用本应用；
- 遵守《中华人民共和国个人信息保护法》《中华人民共和国出境入境管理法》等法律法规；
- 不得用于伪造、变造证件，不得用于冒用他人身份，不得用于任何形式的身份欺诈；
- 作为用人单位、金融机构等处理他人证件信息时，须具备法定事由并履行告知同意义务。

7.2 隐私保护设计

证件芯片数据包含敏感个人信息与生物特征信息（人脸图像），本项目在工程上做了以下约束：

设计点	实现方式
不联网	未申请 INTERNET 权限，数据无任何出境路径
不写外部存储	数据保存在应用私有目录，其他应用无法访问
卸载即清除	私有目录随应用卸载一并删除
排除系统备份	通过 <code>backup_rules.xml</code> 与 <code>data_extraction_rules.xml</code> 显式排除记录目录与配置，避免证件数据进入云备份或换机迁移
导出需用户确认	通过系统文件选择器由用户指定位置，应用不静默落盘
最小权限	仅申请相机与 NFC 两项功能必需权限

7.3 能力边界与后续演进

当前能力边界（如实说明）：

- 仅实现 **BAC**。若证件为 **PACE-only**，则无法读取，应用会明确报错而非静默失败；
- 已实现**主动认证（AA）**，可排除芯片克隆；但未实现**芯片认证（CA）**——CA 只在 PACE 体系下使用，依赖同样的 brainpool 曲线支持，因此与 PACE 一并搁置；
- 未实现 **PACE** 的原因：eMRTD 的 PACE 默认使用 brainpool 曲线，而 JDK / Android 的 JCE 不支持该曲线族，也不支持 AES-CMAC，需自行实现椭圆曲线运算，风险与收益不成比例；
- 信任库**不含证书吊销列表（CRL）**，无法反映已吊销的证书；
- 信任库中有 199 张证书使用了显式 EC 参数（自定义曲线），JDK / Android 无法解析，已在打包阶段剔除；
- 人脸图像支持 JPEG；JPEG 2000 格式可被识别并原样保存，但 Android 原生无法直接显示；
- 往来港澳通行证、往来台湾通行证在**格式与协议层面已支持**（TD1 三行机读区 + BAC），但尚未经过真机验证，实际可用性取决于证件是否支持 BAC 以及 OCR 识别率。

后续演进方向（按性价比排序）：

优先级	方向	预期收益
高	通行证专用 OCR 预处理	卡式证件机读区字号小、反光强，需透视校正与二值化预处理提升识别率
高	PACE 支持	覆盖仅支持 PACE 的新版证件，显著扩大可用范围
中	证书吊销列表（CRL）	信任链已可验证，但无法反映已吊销证书
中	芯片认证（CA）	AA 已实现；CA 依赖 brainpool，需先解决曲线支持
中	JPEG 2000 解码	部分证件人脸图像为该格式，解码后可正常显示
低	多帧投票与透视校正	进一步提升复杂光照下的 OCR 稳定性

7.4 总结

本报告的核心判断可以归纳为一句话：

出入境证件识读能力完全由公开国际标准（ICAO Doc 9303）定义，官方 SDK 的价值在于中国证件专用 OCR 模型、CSCA 证书库与服务端查验结论这类**工程积累**，而不在于算法本身的独占性。因此，**独立实现是一条可行、合法且已经验证的路径。**

本项目用「零授权依赖、零第三方密码学库、完全离线」的方式完成了这条路径：BAC 与安全报文已通过 ICAO 官方向量逐字节验证，76 项单元测试全部通过，并内置了覆盖 103 个国家/地区的 CSCA 信任库，完成从数据完整性到签发国可信的完整验证链路；同时实现主动认证，具备芯片克隆检测能力。源码与 APK 均已交付。

同时必须正视能力边界：缺少 PACE 支持、缺少证书吊销列表，意味着当前实现尚不能替代官方 SDK 在强监管场景下的地位。但在个人自查、自有设备集成、技术研究与教学等场景中，它提供了一条不受授权约束、数据不出设备、代码完全可控的技术选择。

声明

本报告基于公开发布的软件包目录结构、公开头文件、公开接口文档，以及可执行文件的符号表与导入导出表进行分析，不包含对目标软件的反编译、反汇编或源代码还原。报告中涉及的技术分析仅用于学习、研究与技术交流，不构成任何形式的合规意见或法律建议。证件识读涉及敏感个人信息与生物特征信息，请务必在合法合规、取得明确授权的前提下使用相关技术。